

Small Language Models (SLMs)

CompTIA SecAI+ | Section 3: Natural Language Processing and Language Models

Defining Small Language Models

Small Language Models (SLMs) occupy a distinct and increasingly important segment of the AI landscape — models that deliver strong performance on specific tasks while consuming a fraction of the compute, memory, and cost required by frontier large language models. There is no universally agreed parameter threshold separating 'small' from 'large', but practically, SLMs are often models in the range of hundreds of millions to approximately seven billion parameters, versus the hundreds of billions characteristic of frontier LLMs.

The key insight is that model size is not linearly correlated with practical utility for bounded tasks. A model with 7 billion parameters fine-tuned on security alert data can outperform a 70-billion parameter general model on alert classification, because domain-specific fine-tuning compensates for reduced capacity by concentrating it on the relevant distribution of inputs.

Dimension	Small Language Model (SLM)	Large Language Model (LLM)
Parameter count	100M to ~7B	70B to >1T
Inference cost (rough)	Fractions of a cent per query	Cents to dollars per query at scale
Inference latency	Tens of milliseconds	Hundreds of milliseconds to seconds
Hardware requirement	CPU, consumer GPU, edge device	High-end GPU clusters or cloud TPUs
Deployment location	On-device, on-premise, edge	Cloud or on-premise data centre
Task scope	Narrow to moderate	Broad, generalist
Fine-tuning cost	Hours on single GPU	Days to weeks on GPU cluster
Privacy suitability	Excellent — data stays on device	Requires careful data governance if cloud

How SLMs Achieve Efficiency

SLMs are not simply smaller versions of LLMs with reduced capability — they are engineered for efficiency through a suite of techniques that maximise performance per parameter.

Knowledge distillation is a training paradigm where a large 'teacher' model provides soft probability distributions over outputs to train a smaller 'student' model. Instead of learning only from hard labels, the student learns from the teacher's nuanced distribution — capturing reasoning patterns in compressed form. The student SLM can approach the teacher's performance on the target distribution at a fraction of the size.

Quantisation reduces numerical precision of model weights from 32-bit or 16-bit floating point to 8-bit integers or even 4-bit representations. A 7-billion parameter model at 16-bit precision requires approximately 14GB of memory; at 4-bit quantisation it shrinks to approximately 3.5GB — runnable on a

consumer laptop GPU. Accuracy loss from quantisation is typically 1-3% on benchmark tasks, a trade-off well worth the deployment flexibility in most security use cases.

Pruning removes weights or attention heads that contribute minimally to model outputs, reducing both model size and inference compute. Combined with quantisation and distillation, pruned SLMs can run at remarkable efficiency on resource-constrained hardware.

Efficiency Technique	What It Does	Benefit	Trade-off
Knowledge distillation	Teacher LLM trains student SLM on soft predictions	Student captures teacher reasoning with fewer params	Requires teacher model; student may miss rare patterns
Quantisation	Reduces weight precision to 8-bit or 4-bit	2-8x memory reduction; faster inference	Minor accuracy degradation (1-3% typically)
Pruning	Removes low-importance weights and layers	Smaller model, faster inference	Requires careful calibration to avoid accuracy collapse
Mixture of Experts (MoE)	Activates only a subset of model capacity per input	Effectively larger model at SLM inference cost	More complex architecture; routing overhead

Security Applications Requiring SLMs

Certain security use cases are practically impossible with cloud-based LLMs but ideal for SLMs.

Understanding which scenarios demand SLMs — rather than defaulting to the largest available model — is a key competency for AI security professionals.

Endpoint security is the clearest use case. Deploying an SLM directly on an endpoint device enables real-time local threat detection — analysing process behaviour, file access patterns, and network connection attempts without sending telemetry to a cloud service. This matters for several reasons: network-disconnected environments still receive AI protection; sensitive behavioural data never leaves the device; and response latency is measured in milliseconds rather than the round-trip time to a cloud API.

Regulated environments — healthcare (HIPAA), finance (GLBA, PCI-DSS), government (FedRAMP, ITAR, classified networks) — often prohibit transmitting sensitive data to external services. SLMs deployable on-premises allow organisations in these sectors to leverage AI security analysis while maintaining regulatory compliance.

- Real-time endpoint threat detection without cloud connectivity
- On-device phishing URL and email classification before reaching the user
- Local code security scanning in IDE plugins without submitting proprietary code externally
- HIPAA-compliant analysis of medical device logs and clinical data
- Air-gapped network security analysis where no external connectivity is permitted
- Edge gateway security for IoT deployments with thousands of constrained devices
- Low-latency intrusion detection at network edges requiring sub-100ms classification

Open-Source SLMs for Security

The open-source ecosystem has produced several SLMs that security teams can deploy, inspect, and fine-tune without relying on proprietary cloud APIs. This transparency is itself a security property — open models can be audited for backdoors, training data biases, and unexpected behaviours in ways that closed models cannot.

Model	Developer	Parameters	Security Relevance
Mistral 7B	Mistral AI	7B	Strong performance at 7B; instruction-tuned variant widely used for security text tasks
Phi-2 / Phi-3	Microsoft Research	2.7B / 3.8B	Designed for reasoning efficiency; good for constrained endpoint deployment
LLaMA 2 / LLaMA 3	Meta	7B, 13B, 70B	Family spans SLM to LLM; 7B variant practical for on-premise security tooling
Gemma	Google	2B, 7B	Open-weight; designed for on-device and edge deployment
Falcon 7B	TII UAE	7B	Fully open training data; auditable for bias and data sourcing
TinyLlama	Community	1.1B	Ultra-compact for embedded and IoT security applications

Fine-Tuning SLMs on Security Data

One of SLMs' most operationally significant advantages over frontier LLMs is the accessibility of fine-tuning. Fine-tuning a 7-billion parameter model on domain-specific data can be accomplished in hours on a single high-memory GPU, with datasets of a few thousand to tens of thousands of labelled examples. This makes it practical for security teams to create models that understand their specific environment.

A SOC team might fine-tune an SLM on two years of its own historical alerts, labelled by outcome (true positive, false positive, escalated). The resulting model learns the SOC's specific alert patterns and can classify new alerts with reference to the organisation's history rather than relying on generic security knowledge. This organisational specificity can dramatically outperform a general-purpose LLM that has never seen the company's alert patterns.

Key Point: Fine-tuning requires curated, labelled data from your specific environment. The quality of the fine-tuning dataset matters more than its size. A few hundred high-quality, correctly labelled examples of your organisation's specific security patterns can produce a more accurate model than thousands of generic security examples from the internet.

Parameter-efficient fine-tuning (PEFT) techniques like LoRA (Low-Rank Adaptation) reduce fine-tuning cost further by training only a small set of adapter weights rather than all model parameters. LoRA adds less than 1% of the original model's parameters, meaning a team with modest GPU resources can specialise a 7B model for their environment in hours.

SLMs for Privacy-Preserving Security Analysis

Data privacy is one of the most significant barriers to AI adoption in regulated security environments. When a SOC analyst asks an external LLM to analyse a suspicious email, the email content — potentially containing customer PII, confidential business information, or protected health information — leaves the organisation's control. Regulatory requirements are often incompatible with any external disclosure.

SLMs deployed on-premises eliminate this tension. The model runs within the organisation's infrastructure perimeter; inputs and outputs never traverse a network boundary. For industries with strict data residency requirements (EU GDPR, HIPAA, financial regulations), this is not merely preferable — it may be the only compliant path to AI-assisted security analysis.

Real-World Precedent — Italian DPA vs ChatGPT (2023): Italy's data protection authority temporarily banned ChatGPT in March 2023, citing GDPR concerns including lack of legal basis for processing Italian users' personal data. While the ban was lifted after OpenAI provided additional transparency, the incident illustrated that regulatory action against cloud AI services is a credible risk. Organisations processing personal data in AI security workflows must assess compliance before deploying cloud LLMs.

The Economics of SLMs in High-Volume Security Contexts

Cost analysis makes SLMs compelling for high-throughput security applications. Consider an organisation processing one million log events per day through an AI classifier. At frontier LLM API pricing, this is economically prohibitive. The same classification task running on an SLM deployed on-premises may cost less than the electricity to run the server.

Beyond per-query cost, there is the latency dimension. Security event processing that requires real-time decisions — network packet inspection, endpoint behaviour analysis, authentication anomaly detection — cannot tolerate the 500ms to several-second latencies typical of cloud LLM APIs. SLMs running locally respond in 10-50 milliseconds, making them viable for inline security controls.

Metric	Cloud LLM API	On-Premise SLM
Cost per query (rough)	\$0.002 to \$0.06	\$0.00001 to \$0.0001
Latency	200ms to 3s (round trip)	10ms to 100ms (local inference)
Data residency	Third-party cloud	Fully on-premise
Availability dependence	Internet and cloud provider uptime	Local infrastructure only
Scalability	Elastic — pay per use	Fixed capacity — requires hardware investment
Compliance suitability	Varies by cloud region and contract	Full control — meets strictest requirements

Multi-Model Strategies: SLMs and LLMs Together

Sophisticated organisations deploy SLMs and LLMs in a layered architecture that optimises for both cost and capability. The operational model resembles hospital triage: high-volume, routine cases are handled by the fast, cheap resource (SLM), while complex cases requiring deeper reasoning are escalated to the expensive specialist (LLM).

In a SOC context, an SLM running on the SIEM server processes every alert in real time, classifying it and auto-closing obvious false positives. Only alerts flagged as requiring deeper analysis are forwarded to an LLM for contextual reasoning and narrative explanation. This pipeline can reduce LLM API calls by 70-90%, dramatically cutting cost while maintaining analytical quality for complex cases.

Edge Computing and Distributed Intelligence

Edge computing — processing data at the point of generation rather than in centralised data centres — has become a strategic priority for organisations with distributed infrastructure, OT/ICS environments, and IoT deployments. SLMs are the enabling technology for intelligence at the edge.

An industrial facility with air-gapped OT networks, remote equipment, or military forward-deployed systems cannot rely on cloud connectivity for security analysis. SLMs small enough to run on an industrial PC can provide local anomaly detection, protocol analysis, and alert triage — maintaining security intelligence without any external network dependency. This is particularly critical for critical infrastructure where security and reliability consequences of connectivity-dependent security tooling failing during a network outage are unacceptable.

The Future of SLMs: Capable Models Getting Smaller

The trajectory of SLM development is clear: each generation of research produces models that achieve higher benchmark performance at the same parameter count. The Phi series from Microsoft Research demonstrated that training data quality and curriculum can produce models competitive with models several times their size. Mixture-of-experts architectures allow models to route each query to specialised sub-networks, achieving effective LLM-scale knowledge at SLM inference cost.

For AI security professionals, this trajectory has a practical implication: the minimum viable model for most security classification and text analysis tasks is shrinking each year. Staying current on SLM benchmarks and emerging architectures allows security teams to continuously reduce deployment costs while maintaining or improving analytical capability.

Key Terms Glossary

Term	Definition
Small Language Model (SLM)	An AI language model with hundreds of millions to ~7 billion parameters designed for efficient deployment on constrained hardware
Knowledge distillation	Training technique where a large teacher model's output distributions guide a smaller student model's training
Quantisation	Reducing model weight precision (e.g., from 16-bit to 4-bit) to decrease memory footprint and increase inference speed

Pruning	Removing low-importance weights or layers from a trained model to reduce size and increase speed
Fine-tuning	Adapting a pre-trained model on domain-specific data to specialise its performance for a particular task
LoRA	Low-Rank Adaptation — parameter-efficient fine-tuning technique that trains small adapter matrices rather than full model weights
Edge computing	Processing data at the point of generation (device, gateway) rather than in a centralised cloud data centre
Mixture of Experts (MoE)	Architecture where different sub-networks specialise in different input patterns and are selectively activated per query
Data residency	Regulatory or policy requirement that certain data must be stored and processed within a specific geographic or organisational boundary
PEFT	Parameter-Efficient Fine-Tuning — family of techniques for adapting large models with minimal trainable parameters
Air-gapped network	A network physically isolated from the internet and other external networks — requires on-premise AI solutions
Inference latency	The time elapsed from submitting an input to a model to receiving its output — critical for real-time security applications

Quick Revision Checklist

- I can explain the key differences between SLMs and LLMs across size, speed, cost, and deployment
- I can describe knowledge distillation and explain how it enables SLMs to approach LLM performance
- I understand quantisation and can explain the memory-accuracy trade-off it introduces
- I can name at least four security use cases where SLMs are preferable to LLMs
- I can explain why data residency requirements make SLMs essential in regulated environments
- I can name three open-source SLMs and describe their deployment suitability for security contexts
- I understand LoRA fine-tuning and why it makes SLM specialisation accessible to smaller teams
- I can describe a multi-model (SLM plus LLM) triage architecture for a SOC environment
- I can explain why edge computing in OT/ICS environments requires SLMs rather than cloud LLMs
- I can articulate the cost and latency economics that make SLMs essential for high-volume security applications
- I understand that model size is not linearly correlated with task performance — domain fine-tuning matters more

20 Exam-Based MCQs — Small Language Models - Practice MCQs

Test yourself after reading. These questions are written in real exam style — scenario-heavy, with plausible distractors. Read every explanation, including for questions you answered correctly.

Q1. A financial institution must implement AI-powered analysis of transaction fraud alerts. Due to PCI-DSS requirements, no cardholder data may be transmitted to external services. Which deployment architecture BEST meets this requirement?

- A. Use a frontier LLM via a cloud provider's private API endpoint
- B. Deploy an open-weight SLM on-premises and fine-tune it on historical fraud data
- C. Use a cloud LLM with end-to-end encryption of the API channel
- D. Process data in a public cloud region within the same country as the organisation

Answer: B **Explanation:** B is correct. On-premises deployment of an SLM keeps all cardholder data within the organisation's infrastructure, satisfying PCI-DSS data residency and transmission restrictions. A (cloud private endpoint) still transmits data to an external provider. C (encryption) protects data in transit but does not prevent external processing. D (same-country cloud) does not guarantee data never leaves organisational control.

Q2. A security team wants to reduce alert fatigue by auto-closing obvious false positives before they reach analysts. The environment processes 2 million alerts per day and requires decisions within 50 milliseconds. Which model approach is MOST appropriate?

- A. A frontier 70B LLM via cloud API for maximum accuracy
- B. A 7B SLM fine-tuned on historical alert labels deployed locally
- C. A cloud LLM with aggressive caching of common alert types
- D. A rules-based system — AI is not suitable for this latency requirement

Answer: B **Explanation:** B is correct. The requirements are high volume, low latency, and cost-efficiency — all pointing to a locally deployed SLM. A 7B model fine-tuned on the SOC's historical alerts can deliver organisation-specific classification in under 50ms. A (70B cloud LLM) has inherent network latency (200ms+) and prohibitive per-query costs. C does not solve the latency problem for novel alerts. D is incorrect — AI is well-suited if deployed appropriately.

Q3. What is knowledge distillation, and why is it particularly valuable for creating SLMs for security applications?

- A. Compressing training data to reduce storage costs before model training
- B. Training a small student model using the output distributions of a large teacher model to transfer capability at lower parameter count
- C. Extracting key knowledge from a model's weights for regulatory audit purposes
- D. A technique for removing harmful knowledge from a model before enterprise deployment

Answer: B **Explanation:** B is correct. Knowledge distillation has the student model learn from the teacher's soft probability distributions, enabling the student to approximate the teacher's performance with far fewer parameters. A describes data preprocessing. C describes a model audit procedure. D describes safety fine-tuning.

Q4. A 7-billion parameter SLM for security alert classification is fine-tuned using LoRA. What is the PRIMARY advantage of LoRA over full fine-tuning?

- A. LoRA produces a smaller final model than the original SLM
- B. LoRA trains only a small number of adapter parameters, drastically reducing compute and memory requirements
- C. LoRA does not require labelled training data
- D. LoRA fine-tuning prevents the model from forgetting its pre-trained knowledge entirely

Answer: B **Explanation:** B is correct. LoRA inserts low-rank adapter matrices into the model's attention layers and trains only those matrices (adding less than 1% of original parameters) while freezing the base model weights. This reduces GPU memory requirements and training time by orders of magnitude. A is incorrect — LoRA adds adapters to the existing model. C is incorrect — LoRA still requires labelled examples. D is a secondary benefit, not the primary advantage.

Q5. An organisation deploys a 3B-parameter SLM on endpoint devices for local malware classification. During a network outage, the endpoints continue detecting and blocking threats without interruption. Which SLM property enables this?

- A. The SLM connects to a backup cloud provider during primary network outages
- B. On-device inference — the SLM runs entirely on the endpoint CPU/GPU without requiring external connectivity
- C. The SLM caches previous cloud LLM responses for use during outages
- D. Endpoint SLMs synchronise their weights daily and retain a full copy of the cloud LLM

Answer: B **Explanation:** B is correct. On-device SLMs perform inference locally — the entire computation happens on the endpoint hardware without any network call. This makes them resilient to network outages and cloud provider failures. A, C, and D all describe connectivity-dependent architectures.

Q6. A healthcare CISO wants to implement AI analysis of patient monitoring system logs to detect cyberattacks. HIPAA prohibits transmitting PHI to external processors without a BAA. The chosen cloud AI provider does not offer a BAA. What is the BEST solution?

- A. Anonymise the logs before sending to the cloud LLM
- B. Deploy an on-premises SLM fine-tuned on medical device log patterns
- C. Use the cloud LLM without a BAA since the logs are about devices, not patients
- D. Obtain a separate HIPAA waiver for AI security operations

Answer: B **Explanation:** B is correct. On-premises SLM deployment ensures PHI never leaves the organisation's HIPAA-compliant infrastructure. A (anonymisation) is often insufficient — device logs linked to patient records may still contain PHI-adjacent identifiers. C is incorrect — if logs can be linked to patients, they may constitute PHI. D (HIPAA waiver) is not a standard compliance mechanism.

Q7. Which of the following BEST describes the quantisation trade-off when deploying an SLM for security alert classification?

- A. Quantisation improves model accuracy but increases memory requirements
- B. Quantisation reduces model size and inference latency at the cost of a minor accuracy reduction
- C. Quantisation is only applicable to models above 10 billion parameters
- D. Quantisation replaces all model weights with random values to reduce model size

Answer: B **Explanation:** B is correct. Quantisation (e.g., reducing from 16-bit to 4-bit precision) shrinks the model's memory footprint by 2-4x and often speeds inference. The trade-off is typically 1-3% accuracy degradation on benchmarks. A reverses the relationship. C is incorrect — quantisation applies to models of any size. D is not an accurate description.

Q8. A SOC implements a tiered AI pipeline where an SLM auto-closes low-confidence false positives, and only alerts flagged as potentially significant are escalated to a frontier LLM for detailed analysis. What is the PRIMARY benefit of this architecture?

- A. The LLM has access to more alerts and therefore produces higher quality analysis
- B. The SLM handles high-volume routine classification efficiently, reserving expensive LLM inference for complex cases that need it
- C. The SLM validates the LLM's responses before they reach analysts
- D. This architecture eliminates the need for human analysts in the SOC

Answer: B **Explanation:** B is correct. Tiered routing (triage SLM then analysis LLM) optimises the cost-quality trade-off: the SLM handles 80-95% of volume cheaply and quickly, while the LLM processes only the difficult minority. A is incorrect — the LLM sees fewer alerts. C reverses the flow. D is incorrect — human judgment remains essential.

Q9. What distinguishes Mixture of Experts (MoE) architecture from a standard dense SLM, and what security deployment advantage does it provide?

- A. MoE uses multiple specialised models that vote on each prediction through ensemble methods
- B. MoE activates only a subset of model capacity per input, achieving high effective model capacity at SLM-level inference cost
- C. MoE trains separate models for each security domain and routes queries via an external router
- D. MoE is a training technique only and does not affect inference cost

Answer: B **Explanation:** B is correct. In MoE, the model contains multiple expert sub-networks but only a few are activated per token via a learned router. This means the model has the parameter count of a large model but the inference compute of a small one. A describes ensemble methods, not MoE. C describes an external multi-model routing system. D is incorrect — MoE directly affects inference cost.

Q10. An OT security team at an energy company needs AI-assisted anomaly detection for an air-gapped ICS network that physically cannot connect to the internet. What is the ONLY viable AI deployment option?

- A. A frontier cloud LLM accessed via a secure VPN tunnel to the air-gapped network
- B. A rule-based system — AI cannot function without internet connectivity

- C. An SLM deployed on servers within the air-gapped network perimeter
- D. A cloud LLM running on the internet side with logs manually transferred via USB

Answer: C **Explanation:** C is correct. By definition, an air-gapped network has no internet connectivity. An SLM deployed on servers within that perimeter runs entirely locally. A (VPN to air-gapped) contradicts the definition of air-gapped. B is incorrect — AI inference can operate entirely offline. D (USB transfer) introduces a removable media attack surface.

Q11. Which of the following is a security-relevant advantage of open-weight SLMs (e.g., LLaMA, Mistral, Falcon) over proprietary closed-source models?

- A. Open-weight models are always more accurate than closed-source models
- B. Open-weight models can be audited for backdoors, training data biases, and unexpected behaviours
- C. Open-weight models do not require any fine-tuning to perform well on security tasks
- D. Open-weight models are exempt from data privacy regulations since their weights are public

Answer: B **Explanation:** B is correct. The ability to inspect model weights and architecture is a meaningful security property enabling auditing for supply-chain attacks, bias assessment, and independent capability evaluation. A is incorrect — open vs closed does not determine accuracy. C is incorrect — domain fine-tuning is still highly beneficial. D is incorrect — data privacy regulations govern data processed by the model, not whether weights are public.

Q12. The Italian data protection authority temporarily banned ChatGPT in 2023 citing GDPR concerns. What principle does this incident MOST directly illustrate for AI security deployments?

- A. AI systems must be banned until regulators provide explicit approval
- B. Cloud-based AI services may be subject to regulatory action affecting availability and compliance status
- C. GDPR only applies to Italian organisations and is irrelevant outside Italy
- D. Cloud AI providers are always non-compliant with EU data protection law

Answer: B **Explanation:** B is correct. The incident illustrates that cloud AI service availability is subject to regulatory action — a risk that security and compliance teams must assess. On-premises SLM deployment eliminates this specific risk. A (blanket AI ban) is an overstatement. C is incorrect — GDPR has extraterritorial reach. D is an overstatement — cloud providers can achieve GDPR compliance with appropriate controls.

Q13. A security team fine-tunes a 7B SLM on two years of historical SIEM alerts with analyst-verified labels. The model achieves 92% accuracy, outperforming a general-purpose 70B LLM that achieved 78%. What explains this result?

- A. Larger models are always less accurate — model performance degrades with scale
- B. The fine-tuned SLM specialised on the organisation's specific alert patterns, which a general LLM has never encountered

- C. The 70B LLM was not fine-tuned, making the comparison invalid
- D. 92% accuracy is a statistical anomaly — this result would not be reproducible

Answer: B **Explanation:** B is correct. Domain-specific fine-tuning aligns the SLM precisely with the input distribution it encounters in production. A large general LLM has broad knowledge but has never seen this organisation's specific alert patterns. A is incorrect — larger models are generally more capable on broad benchmarks. C is irrelevant to whether the comparison is valid. D is speculation.

Q14. Which statement BEST describes the relationship between model parameter count and security task performance?

- A. More parameters always produces better performance on any security task
- B. Parameter count and task performance are unrelated — only training data quality matters
- C. For bounded, well-defined tasks, a domain-fine-tuned SLM can outperform a larger general LLM
- D. SLMs are suitable only for simple keyword matching — complex security analysis requires LLMs

Answer: C **Explanation:** C is correct. On narrow, well-defined tasks with sufficient domain-specific training data, smaller specialised models regularly outperform larger general models. The general LLM spreads its capacity across all domains; the SLM concentrates its capacity on the target distribution. A is incorrect. B is incorrect — parameter count does matter for breadth of capability. D understates SLM capability.

Q15. A security engineer needs to deploy an SLM for real-time URL classification at a network proxy. The model must classify 10,000 URLs per second as benign or malicious. What specification is MOST critical when selecting the SLM?

- A. Maximum context window length (number of tokens per input)
- B. Inference latency and throughput on available hardware
- C. Number of supported languages for multilingual URL analysis
- D. Model accuracy on academic NLP benchmarks

Answer: B **Explanation:** B is correct. At 10,000 classifications per second, inference latency and throughput are the binding constraints. A (context window) matters for long documents but URLs are short. C (multilingual support) may be relevant but is secondary to meeting the throughput requirement. D (academic benchmarks) measures general capability, not production throughput.

Q16. What is the PRIMARY security risk introduced when employees use consumer-facing LLM services rather than enterprise-deployed SLMs for work tasks?

- A. Consumer LLM services produce lower quality outputs than enterprise models
- B. Employees may inadvertently submit sensitive organisational data to a third-party service outside organisational data governance controls
- C. Consumer LLMs have higher inference latency than enterprise SLMs
- D. Consumer LLMs cannot be fine-tuned on organisational data

Answer: B **Explanation:** B is correct. The fundamental risk is data governance — when employees paste proprietary code or confidential documents into a consumer AI service, that data leaves the organisation's control and is processed by a third party. A, C, D are secondary operational considerations, not the PRIMARY security risk.

Q17. Which technique allows an SLM to achieve the knowledge breadth of a larger model while maintaining SLM-level inference cost?

- A. Transfer learning from a pre-trained image classification model
- B. Mixture of Experts (MoE) — routing each query to specialised sub-networks within the model
- C. Multi-task learning with simultaneous training on all security domains
- D. Increasing quantisation from 4-bit to 16-bit precision during inference

Answer: B **Explanation:** B is correct. MoE allows a single model to contain many specialised expert networks but activates only a sparse subset per inference, achieving the parameter count of a large model at the compute cost of a small one. A is a different training paradigm unrelated to inference efficiency. C is a training strategy that increases breadth but does not reduce inference cost. D increases cost and memory requirements.

Q18. A company CISO argues 'we should always use the most powerful model available.' A security architect disagrees. Which argument BEST supports the architect's position?

- A. More powerful models are always more expensive and the company wants to reduce costs
- B. Deploying a larger model introduces more complexity and therefore more security vulnerabilities
- C. For specific bounded tasks, a domain-fine-tuned SLM can match or exceed a frontier LLM's performance at far lower cost, latency, and data-sharing risk
- D. Regulatory bodies prohibit the use of frontier LLMs in enterprise security contexts

Answer: C **Explanation:** C is correct. The architect's position is supported by the principle of fitness for purpose — model selection should be driven by task requirements. Domain fine-tuning enables SLMs to match frontier models on specific tasks while offering advantages in cost, latency, and data privacy. A is partially correct but incomplete. B is an unsupported generalisation. D is not accurate.

Q19. An IoT security platform needs to deploy threat detection on 50,000 sensors with limited CPU and 512MB of RAM each. Which AI deployment approach is feasible?

- A. A 70B parameter LLM running on each sensor
- B. A cloud LLM with direct connectivity from each sensor
- C. A heavily quantised SLM (e.g., 100M to 500M parameters at 4-bit) running on each device
- D. AI threat detection is not feasible on resource-constrained IoT devices

Answer: C **Explanation:** C is correct. Aggressively quantised SLMs can run in under 512MB RAM — a 500M parameter model at 4-bit quantisation uses approximately 250MB. A (70B LLM) would require hundreds of GB of memory. B (cloud LLM) requires reliable network connectivity and exposes sensor data to external transmission. D understates current SLM capability.

Q20. A SOC manager notes cloud LLM costs have grown to \$50,000 per month due to high alert volume. The security architect recommends transitioning to an on-premise SLM. Which metric should the architect present FIRST to justify the investment?

- A. The SLM's score on academic NLP benchmarks
- B. Total cost of ownership comparison including SLM hardware, maintenance, and fine-tuning vs current cloud LLM spend
- C. The number of parameters in the proposed SLM
- D. The accuracy of the SLM on publicly available security datasets

Answer: B **Explanation:** B is correct. A business justification for infrastructure investment requires total cost of ownership comparison — hardware acquisition, ongoing maintenance, model updates, and fine-tuning costs weighed against current cloud LLM spending. A (academic benchmarks) measures general capability, not business ROI. C (parameter count) is an architectural characteristic. D (public dataset accuracy) measures generalisation, not SOC-specific performance.